

JAYS SHOP

Digital Retail Platform — Management Report

CLOUD STORAGE (CLOUDFLARE R2) IMPLEMENTATION & STATUS

What changed today, why it mattered for the business, current status, and the decisions management needs to make. Technical detail is in the appendix.

Prepared for Management — July 27, 2026

1. Executive Summary

Jays Shop's product photos and hero videos (the images and video banners on the storefront's home, shop, and gallery pages) are now served from **Cloudflare R2**, a cloud storage service, instead of the previous provider (Vercel Blob storage). This change was necessary, cost-motivated, and is now working, but it took most of a working day to get fully stable because of four separate technical problems that each masked the next. The underlying cause of the last and most serious problem was a stray extra character in a stored credential — not a design flaw — and it has been fixed and confirmed working.

Separately, and unrelated to the R2 migration itself, a document containing live infrastructure credentials was accidentally committed to the project's source history earlier today, and several scripts contained hardcoded staff/admin passwords in plain text. Both issues have been addressed (credential rotation and password removal, respectively), but two items below require a management decision and are not yet closed out.

What changed today

- Direct browser-to-storage uploads for hero videos went live, using short-lived, single-use upload links (**presigned URLs**, explained in Section 3) so large video files no longer pass through the website's own servers.
- A cross-origin access policy (**CORS**, a browser security setting a storage provider must explicitly allow) was configured on the storage bucket so the admin dashboard, running in a browser, is permitted to upload directly to it.
- Four stacked technical faults surfaced and were fixed one after another (detailed in Section 5); the final and true root cause was a whitespace/newline character accidentally embedded in a stored credential value, which silently broke the cryptographic signature every upload request relies on.
- A credential-bearing reference document was found committed to the repository; the exposed credential has been rotated, and hardcoded plaintext passwords were removed from four internal scripts in favor of environment variables.

Why it mattered

Before today's fixes, admin staff could not reliably upload new hero images or videos to the storefront — image uploads failed outright with a server error, and video uploads failed in a way that looked like a browser security block. Both were symptoms of the same underlying credential problem. This blocked the marketing/merchandising workflow for updating the site's visual banners, though it did not affect checkout, payments, or the product catalog.

Current status

Resolved and verified working.

All identified upload failures are fixed. A hero video upload was completed end-to-end after the final fix and confirmed live (evidence in Section 5). The remaining open items below are governance/compliance decisions, not active technical outages.

What still needs a decision

- **Confirm the Vercel hosting plan tier.** If the account is still on Vercel's free "Hobby" plan, that plan's terms prohibit commercial use — a real compliance exposure for a revenue-generating retail site, independent of any technical concern (Section 7).
- **Rotate admin and staff account passwords.** Plaintext passwords for admin/staff accounts were found hardcoded in scripts in git history; even though the code has been fixed, the specific password values were exposed in project history and should be treated as compromised (Section 6, Section 7).

2. Why We Moved to Cloudflare R2

The storefront's hero images and videos were previously hosted on **Vercel Blob**, a pay-as-you-go file storage add-on from the same company that hosts the website. Two commits from earlier this month (**e5acfb**e, dated July 27, and the broader migration completed in **359ec5b**) confirm the team moved away from Vercel Blob specifically to stop what the commit message describes as “blob data-transfer burn” on hero videos — i.e., the cost/quota consumed every time a visitor's browser downloaded a hero video from that storage service.

Plain-English cost explanation: most cloud storage providers, including Vercel Blob, charge for “egress” — the data transferred out to visitors' browsers every time an image or video is viewed. A popular hero video watched thousands of times generates real, metered egress cost and can hit a plan's included allowance. **Cloudflare R2 charges \$0 for egress**, regardless of volume; only storage space and a small number of write/read operations are billed, and Jays Shop's current usage sits far inside R2's free tier (Section 4).

A note on the HTTP 403 framing.

This report was asked to verify a claim that the prior Vercel Blob store had hit a plan limit and was returning HTTP 403 errors that blanked the site's hero imagery. The repository's commit history and code confirm the *cost/quota motivation* for leaving Vercel Blob (commit e5acfb's message explicitly cites stopping “data-transfer burn”) and confirm that a static-image fallback was added specifically to handle video/image load failures gracefully. However, no HTTP 403 status code, error log, or support ticket referencing that specific error is present anywhere in the repository or its commit history. **This specific detail (a 403 response blanking hero imagery) is marked unverified** rather than stated as fact; the cost/quota motivation for the migration itself is confirmed.

Beyond the immediate cost driver, moving fully off Vercel Blob (commit **359ec5b**, “remove Vercel Blob dependency from all uploads”) also removes a second, unrelated dependency on Vercel's own infrastructure limits for file uploads, discussed further in Section 7.

3. What Was Implemented

In plain terms: product and hero media (images and videos) now live in a Cloudflare R2 storage bucket — conceptually similar to a secure, organized folder in the cloud. There are two upload paths, and one serving path:

Uploading a hero video (large files)

- An admin staff member selects a video in the dashboard.
- The website's server hands the browser a **presigned URL** — a temporary, single-use web address (valid for 5 minutes) that grants permission to upload directly to the storage bucket without the storage credentials ever reaching the browser.

- The browser uploads the video file **directly to Cloudflare R2**, bypassing the website's own server entirely. This matters because it avoids the website server's own file-size and processing-time limits, which matter more for large video files than for photos.

Uploading other images (products, brands, gallery, etc.)

- These smaller files are still uploaded through the website's own server, which then places the file into the R2 bucket on the browser's behalf.

Serving media to shoppers

- Once stored, every image and video is served to site visitors from a public R2 web address (Section 4) — the same way any other website image is served, with no login or credential required to view it.

4. Configuration State

Storage is configured via five environment variables (named settings stored securely outside the codebase). **Their values are never printed in this report, its appendix, or anywhere in the source "code" — only their names and purpose are documented below, consistent with standard secret-" handling practice.**

Variable name	Purpose
R2_ENDPOINT	The Cloudflare R2 account's API address.
R2_ACCESS_KEY_ID	Identifies the API credential used to authenticate (not a password by itself).
R2_SECRET_ACCESS_KEY	The private credential used to cryptographically sign each request.
R2_BUCKET_NAME	The name of the storage bucket (container) media is stored in.
R2_PUBLIC_URL	The public web address used to serve stored media to site visitors.

All five variables are set in **Vercel's Production environment configuration** (the hosting platform's settings panel), scoped only to Production, and stored **encrypted at rest** by Vercel. They are not present in the source code or in any file the codebase writes to disk; the source code only ever reads them from the runtime environment. This was confirmed directly by reading `src/lib/media/r2.server.ts`, which reads all five exclusively via `process.env.*` and documents them by name in a code comment, never as literal values.

5. Problems Encountered and Resolved Today

Getting hero-media uploads fully working today required diagnosing **four separate problems** that surfaced one after another, each masking the next. This section states plainly which was the true underlying ("root") cause and which were real, independent, defensive fixes that were not themselves the cause of the failures that persisted after they were applied.

Sequence of events, in order

#	Problem	Commit	Verdict
1	The storage bucket had no CORS policy at all (a browser security setting that must explicitly allow direct uploads from the admin dashboard's web address).	52e071c	Real, fixed. Not the final cause.

2	A checksum mismatch: the upload software's default settings attached a checksum for an empty file to the upload authorization, which no longer matched once the browser sent the real (non-empty) video file.	11d9736	Real, fixed. Not the final cause.
3	A theory that the storage address (endpoint) was malformed by duplicating the bucket name in the file path. Defensive normalization code was added, but investigation later proved this was never actually happening in production.	4c086ac / d2e281f	Defensive only. Confirmed NOT the cause.
4	The true root cause: a stray whitespace/newline character embedded in the stored access-key or secret-key credential value, most likely from a copy-paste into the hosting dashboard. This silently corrupted the cryptographic signature every upload request depends on.	06b2db2	Confirmed root cause. Fixed.

Why the same credential problem looked like two different bugs: image uploads pass through the website's own server, where the corrupted credential caused an outright crash (a server error). Video uploads use the presigned-URL method (Section 3), where the corruption instead silently produced an invalid signature; Cloudflare R2 rejected the resulting request with a generic authentication error that, because it omitted a required browser-security header, was misreported by the browser as a "CORS" failure — a red herring that pointed investigation toward the (already-fixed) CORS policy rather than the credential itself.

Verification of the fix

A hero video upload was performed end-to-end after the final fix; the resulting live web address " returned a successful HTTP 200 response with a file size matching the uploaded video " (content-length: 6470592 bytes). This was reported by the engineer who " performed the deploy and is treated in this report as the available evidence of success; it was not " independently re-executed while preparing this document.

6. Security Incident and Response

Summary: credential exposure found, rotated, and confirmed. History not rewritten — by design.

A document containing live Cloudflare R2 credentials was committed to the project's git history earlier today (commit 36fd9c2, “docs: add Cloudflare R2 credentials and configuration reference PDF”). The exposed access credential has been rotated (replaced with a new one at the provider), and that rotation has been independently verified. The old credential-bearing file itself remains in the repository's git history and current file tree; a full history purge was evaluated and deliberately not carried out.

What happened

- Commit **36fd9c2** (this morning, July 27) added docs/jayshop-cloud-storage-reference.pdf and its source .tex file, described in its own commit message as containing “R2 bucket details, API credentials, Vercel env vars, and important URLs.” Both files are still present and tracked in the repository as of this report.
- A later commit (**9ad862a**, “gitignore credential reference docs to prevent recurrence”) added a rule to the project's ignore-list so this specific file pattern cannot be accidentally re-added going forward. This prevents a repeat, but does not remove the file that is already committed.

Why history was not rewritten

Rewriting git history to delete the file (e.g. with a history-purge tool) was considered and deliberately rejected as the remediation here. **Rotating the exposed credential is the authoritative fix:** once rotated, the old credential value sitting in git history is inert and cannot be used to access anything, regardless of who can still see it. A history rewrite, by contrast, does not remove data from GitHub's own servers (prior commits typically remain reachable/recoverable there for a period, and anyone who already cloned the repository keeps a full copy regardless), while also being disruptive to every collaborator's local copy of the repository. Given that, rotation was judged the correct and sufficient fix, and a purge was not performed.

Plaintext passwords removed from scripts

Separately, commit **a74c73d** (“fix(security): remove hardcoded plaintext passwords from " scripts, use env vars”) removed hardcoded staff/admin account passwords that had been written " directly into four files: docs/capture_screenshots.js, " scripts/check-passwords.ts, " scripts/reset-admin-password.ts, and " scripts/reset-staff-password.ts. Each script now requires the password to " be supplied via an environment variable at run time instead of being stored in the file. As with the " credential document above, the specific password values that were hardcoded remain visible in this " repository's git history and should be treated as exposed regardless of the code fix (see Section 7).

7. Open Items Requiring a Management Decision

Item	Recommendation
Rotate admin and staff account passwords	The specific plaintext password values found in git history (commit history predating a74c73d) should be treated as exposed. Recommend rotating all admin and staff account passwords now, independent of the code fix already applied.
Verify the Vercel hosting plan tier (Hobby vs. paid)	Vercel's free "Hobby" plan terms prohibit commercial use. Jays Shop is a revenue-generating retail platform; if the account is still on Hobby, recommend upgrading to a paid plan promptly to close this compliance exposure. This could not be confirmed from the repository or CLI tooling available while preparing this report and needs confirmation directly in the Vercel billing dashboard.

Appendix — Technical Detail

This appendix restates the material above with implementation-level detail, for engineering or "technical-audit reference. No credential values appear anywhere below.

A.1 Commits reviewed and verified (via ``git log`` / ``git show``)

52e071c	chore(r2): add CORS configuration helper and script
11d9736	fix(r2): disable auto CRC32 checksum on presigned PUT uploads
4c086ac	fix(r2): normalize R2_ENDPOINT that includes bucket name as path suffix
d2e281f	diag(r2): log presigned URL pathname to surface doubled-bucket paths
06b2db2	fix(r2): trim R2 env vars to guard against ERR_INVALID_CHAR recurrence
a74c73d	fix(security): remove hardcoded plaintext passwords from scripts, use env vars
9ad862a	chore: gitignore credential reference docs to prevent recurrence
36fd9c2	docs: add Cloudflare R2 credentials and configuration reference PDF
e5acfbe	fix(hero): stop blob data-transfer burn for hero videos
359ec5b	refactor(media): remove Vercel Blob dependency from all uploads

A.2 ``src/lib/media/r2.server.ts`` — S3 client setup

- `requestChecksumCalculation`: `'WHEN_REQUIRED'` is set on the `S3Client` in `getClient()`, added in commit 11d9736, preventing the AWS SDK v3 default (`WHEN_SUPPORTED`) from attaching a checksum computed over an empty body to presigned `PutObjectCommand` requests.
- `normalizeR2Endpoint()` strips a trailing `/<bucketName>` path suffix from `R2_ENDPOINT` if present (commit 4c086ac), tolerating both the bucket-suffixed and bucket-less forms of the Cloudflare dashboard's displayed endpoint. Server logs a host-only warning (no credentials) when this normalization triggers.
- All five R2 environment variables (`R2_ENDPOINT`, `R2_ACCESS_KEY_ID`, `R2_SECRET_ACCESS_KEY`, `R2_BUCKET_NAME`, `R2_PUBLIC_URL`) are read with `?.trim()` applied (commit 06b2db2), confirmed present at lines 58, 67-68, 92, and 98 of the file as read directly for this report.

A.3 ``src/app/api/admin/hero-slides/presigned-url/route.ts``

- GET route, gated by `requireRole(req, 'gallery:write')`, validating file name, content type (MP4/WebM only), size (max 50 MB), and scope before calling `getPresignedR2UploadUrl()`.
- Diagnostic logging (commit d2e281f) logs only new `URL(presignedUrl).pathname` — explicitly never the query string, which carries the SigV4 request signature — so a doubled-bucket path would be visible in Vercel logs without exposing any credential material.

A.4 `scripts/configure-r2-cors.ts`

A one-off runner that calls `configureR2Cors()` " (src/lib/media/r2.server.ts) against a hardcoded list of three allowed " origins (production URL, a preview URL, and localhost:3000). Confirmed present in " package.json as the npm script " r2:configure-cors (added in commit 11d9736), so it can be run via " npm run r2:configure-cors instead of being invoked ad hoc.

A.5 File-by-file change list (commits reviewed)

Commit	Files changed
52e071c	scripts/configure-r2-cors.ts (new); src/lib/media/r2.server.ts (+27); docs/hero-video-upload-fix-summary.pdf/.tex (new, no secrets)
11d9736	package.json (+3/-1); src/lib/media/r2.server.ts (+7)
4c086ac	src/lib/media/r2.server.ts (+33/-2)
d2e281f	src/app/api/admin/hero-slides/presigned-url/route.ts (+7)
06b2db2	src/lib/media/r2.server.ts (+13/-5)
a74c73d	docs/capture_screenshots.js (+9/-2); scripts/check-passwords.ts (+10/-2); scripts/reset-admin-password.ts (+11/-2); scripts/reset-staff-password.ts (+12/-2)
9ad862a	.gitignore (+3)

A.6 Items explicitly marked unverified in this report

- The claim that the prior Vercel Blob store returned HTTP 403 errors that blanked hero imagery: no such status code, error log, or ticket referencing it was found in the repository. The cost/quota motivation for leaving Vercel Blob is confirmed; the specific 403 detail is not.
- That the exposed R2 credential's rotation was "independently verified": this report relies on that being reported by the engineer who performed it. No rotation confirmation record (e.g. a provider audit log export) exists in the repository itself.
- The current Vercel hosting plan tier (Hobby vs. paid): not observable from the repository or from CLI tooling available while preparing this report.

This report contains no credentials, API keys, passwords, tokens, or connection strings. Environment variable names and file/commit references are included for traceability only.